

MEDSECURE SAS · HEALTHTECH · SAAS · HEALTH DATA

Information Security Management System

Leadership & Commitment — Clause 5

This document comprises two distinct deliverables covering Clause 5 of ISO/IEC 27001:2022:

Part I	Information Security Policy	Clauses 5.1 & 5.2
Part II	ISMS Roles & Responsibilities	Clause 5.3

Document ID	SMSI-MDS-C5-001
Version	1.0 — DRAFT
Date	May 2026
Author	Junior Abakar — GRC Analyst
Reviewer	CISO — MedSecure SAS (TBD)
Approved By	CEO — MedSecure SAS (TBD)
Last Updated	May 2026
Review Frequency	Annual
Next Review	May 2027
Classification	Confidential — For internal use only

This document is provided for informational and educational purposes only as part of a personal GRC portfolio project. It does not constitute professional advice. MedSecure SAS is an entirely fictional organisation; any resemblance to a real entity is coincidental.

Contents

1	Purpose	3
2	Business Objectives	3
3	Information Security Objectives	3
4	Commitment to Continual Improvement	4
5	Compliance with Requirements	4
6	Responsibilities	4
7	Leadership Commitment	4
8	Communication & Availability	5
9	Approval — Part I	5

Part I - Clauses 5.1 & 5.2 Information Security Policy

1 Purpose

This Information Security Policy establishes MedSecure SAS's commitment to protecting the **confidentiality, integrity, and availability** of its information assets and systems. It sets out the principles and expectations for managing information security across the organisation, ensuring alignment with **ISO/IEC 27001:2022** and supporting the effective operation of the Information Security Management System (ISMS).

This policy is specifically scoped to the ISMS boundary defined in document **SMSI-MDS-C4-001** (Clause 4). It applies to all **45 employees**, contractors, systems, and services within that defined scope — including the cloud-based SaaS patient records management platform, AWS infrastructure (eu-west-3), and supporting internal tools.

2 Business Objectives

MedSecure SAS develops and operates a **cloud-based SaaS patient records management platform** serving private clinics and hospital groups across France. The company's primary business objectives are to deliver a secure, reliable, and compliant healthcare SaaS solution, grow its customer base within the French health sector, maintain high system availability for clinical users, and meet the security expectations of hospital clients — supporting market competitiveness and long-term commercial sustainability.

To fulfil this, MedSecure SAS must demonstrate compliance with the regulatory framework governing health data in France (**GDPR Article 9, HDS, NIS 2 Directive**) and obtain **ISO 27001:2022 certification** within 6 months as a contractual prerequisite for signing a **2 M hospital group contract**.

3 Information Security Objectives

To support its business goals, MedSecure SAS has established the following information security objectives. These objectives are **measurable, regularly reviewed, and integrated into relevant business processes**, in accordance with ISO/IEC 27001:2022 Clause 6.2.

#	Objective	Measure & Target
O1	Ensure the confidentiality of patient health data	Zero unauthorised disclosures of GDPR Art. 9 special-category data. Measured via incident tracking (monthly).
O2	Maintain the integrity of patient records and audit logs	No unauthorised alterations detected. Integrity checks and log reviews conducted monthly.
O3	Ensure availability of the SaaS platform	Platform uptime $\geq 99.5\%$ per month, as per hospital client SLA requirements.
O4	Minimise the risk of unauthorised access to information assets	MFA enforced on all systems; quarterly access rights reviews (Annex A.5.18).
O5	Promote security awareness across all staff	100% of 45 employees complete annual security awareness training (Annex A.6.3).
O6	Achieve ISO/IEC 27001:2022 certification within 6 months	Stage 1 audit readiness by agreed deadline — primary contractual driver (2 M hospital contract).

4 Commitment to Continual Improvement

MedSecure SAS is committed to **continually improving** the effectiveness of its ISMS by regularly assessing risks, monitoring control effectiveness, and addressing security incidents and nonconformities. Improvement efforts are guided by:

- **Annual internal audits** (Clause 9.2);
- **Management reviews** at least once per year (Clause 9.3);
- **Corrective actions** arising from nonconformities (Clause 10);
- **Stakeholder feedback**, including hospital group clients and regulatory authorities (CNIL, ANS).

5 Compliance with Requirements

MedSecure SAS ensures that the ISMS complies with **ISO/IEC 27001:2022** requirements and all applicable legal, regulatory, and contractual obligations, including:

- **GDPR Article 9** — processing of special-category health data, mandatory DPIA, and breach notification to CNIL within 72 hours;
- **HDS Certification** (Agence du Numérique en Santé) — hosting health data on behalf of healthcare providers;
- **NIS 2 Directive (EU 2022/2555)** — incident reporting obligations as a digital service provider in the health sector;
- **Hospital group contractual requirements** — ISO 27001:2022 and HDS certification as preconditions for contract signature.

6 Responsibilities

The **CEO** is ultimately accountable for information security at MedSecure SAS. The **CISO (Information Security Manager)** is responsible for the development, implementation, and maintenance of the ISMS. The **GRC Analyst** manages day-to-day governance, risk, and compliance activities. All employees and contractors are expected to understand and comply with this policy and its supporting procedures. Detailed ISMS-specific responsibilities are documented in **SMSI-MDS-C5-002** (Part II of this document).

7 Leadership Commitment

MedSecure SAS's executive leadership is fully committed to establishing, implementing, maintaining, and continually improving the ISMS in accordance with **ISO/IEC 27001:2022**. This commitment is evidenced by:

- **Formal approval** and signature of this policy by the CEO;
- **Allocation of resources** — human, financial, and technological — required for ISMS implementation and certification;
- **Active participation** in management reviews and strategic security decisions;
- **Promotion of a security culture** across all levels of the organisation, including mandatory training and security-by-design in product development.

This policy reflects top management's commitment to fulfilling all applicable requirements and enhancing the overall effectiveness of the ISMS.

8 Communication & Availability

This policy is:

- **Communicated** to all 45 employees upon onboarding and at each update;
- **Available** on the internal intranet (Confluence / Google Workspace);
- **Accessible to relevant external parties** upon request (clients, auditors, regulatory authorities);
- **Reviewed annually**, or upon any significant change in the organisational, regulatory, or threat context.

9 Approval — Part I

Role	Name	Date	Signature
Author	Junior Abakar — GRC Analyst	May 2026	_____
Reviewer	CISO — MedSecure SAS	TBD	_____
Approved By	CEO — MedSecure SAS	TBD	_____